Relatório completo das modificações · Smart Attendance

Período: 8 e 9 de novembro de 2026
Base: commit `6411a3e` ("resolvendo problemas de vazamento de dados"), branch `main`
Repositório oficial: `AtilaAlvesRodrigues/smart-attendance` · **Fork de deploy:** `jooaoleonardi/smart-attendance`
Produção: `https://smart-attendance-nine-alpha.vercel.app`

---

1. Resumo

Foram atendidos os sete itens do pedido original, e mais correções de segurança que surgiram durante o trabalho.

Indicador	Valor
Pull Requests	8 (6 mergeados, 2 abertos aguardando merge)
Commits (sem merges) na `main`	15 (mais 2 nos PRs abertos 61 e 62)
Arquivos alterados na `main`	65 (20 novos, 45 modificados)
Linhas	+2.062 / −223
Testes automatizados	209 → **238** (todos passando)
Falhas de segurança registradas	11 (5 resolvidas, 2 parciais, 4 abertas)
Deploys de produção feitos	2, ambos pela CLI da Vercel
PHP em produção	**8.5.12**, versão que corrige as CVE-2026-109618 e CVE-2026-109619

Os sete itens pedidos

#	Pedido	Situação
1	QR Code que muda a cada 30 segundos	Feito e em produção
2	Content-Security-Policy	Feito e em produção
3	Documento de falhas de segurança	Feito (`docs/falhas-de-seguranca.md`)
4	Definir a licença do repositório	Feito (MIT)
5	Relatório com revisão do projeto	Feito
6	Deploy automático da Vercel pelo GitHub	Feito, via fork; o primeiro deploy automático ainda não foi testado
7	Revisão das Actions, melhorias e novas actions	Feito

2. Mudanças na aplicação

2.1 QR Code rotativo (30 segundos)

Problema: o QR Code valia 2 horas. Uma foto enviada a quem estava fora da sala registrava presença enquanto a chamada estivesse aberta.

Solução: a URL do QR leva um token `?t={janela}.{assinatura}`.

- A assinatura é um HMAC-SHA256 do código da aula e da janela de 30 s, com a `APP_KEY` (`app/Support/QrToken.php`). Não usa banco nem cache: professor e servidor chegam ao mesmo valor só com a chave e o relógio.
- O servidor aceita a janela atual e a anterior, então uma foto vale **no máximo 60 segundos**. A comparação é em tempo constante (`hash_equals`).
- A tela do professor renova o QR sozinha, a partir da rota `GET /professor/presenca/token/{código}` (limite de 60 por minuto, só para o professor dono da chamada aberta), e mostra a contagem "Troca em N s". A renovação também vale para o modo de projeção em tela cheia.
- Se o aluno escaneia sem estar logado, o token fica guardado na sessão (`pending_attendance_token`) e segue depois do login e da criação de senha.
- Um link velho mostra "Este QR Code expirou. Escaneie o código que está na tela do professor agora."

Arquivos: `app/Support/QrToken.php` (novo), `PresencaController`, `AlunoLoginController`, `CriarSenhaController`, `resources/views/professor/presenca/gerar.blade.php`, `resources/views/aluno/home.blade.php`, `routes/web.php`.

Comportamento novo: quem escaneia precisa fazê-lo na hora. Se o login demorar mais de 1 minuto, é preciso escanear de novo.

Limite conhecido: um aluno presente ainda pode mandar o link do momento a um colega ausente, que confirma dentro da janela. Registrado como SEC-05.

2.2 Content-Security-Policy com nonce

Situação anterior: havia uma CSP, mas com `'unsafe-inline'` em scripts e estilos, o que anulava a proteção contra XSS, e `fonts.googleapis.com` liberado como origem de script.

Solução (`app/Http/Middleware/SecurityHeaders.php`):

Diretiva	Valor
`default-src`, `connect-src`	`'self'`
`script-src`	`'self'` e o **nonce da requisição** (nenhuma CDN)
`style-src`	`'self'`, o nonce e `https://fonts.googleapis.com`
`script-src-attr`, `style-src-attr`	`'unsafe-inline'` (**temporário**, ver SEC-08)

Diretiva	Valor
`object-src`	`'none'`
`base-uri`, `form-action`	`'self'`
`frame-ancestors`	`'none'`
`font-src` / `img-src`	`'self'` + `fonts.gstatic.com` / `'self'` + `data:`
`upgrade-insecure-requests`	só em requisições HTTPS

- Um nonce novo é gerado a cada requisição e as tags do `@vite` também o recebem.
- Todo `<script>` e `<style>` em bloco das views usa a diretiva `@nonce` (25 views). Um bloco injetado por um atacante não tem o nonce e o navegador não o executa.
- O middleware passou de grupo `web` para **global**, então a página 404 também recebe os cabeçalhos.
- Quem criar um `<script>` ou `<style>` novo precisa usar `<script @nonce>`. O `CspCoberturaTest` falha se alguma tela esquecer.

2.3 Host confiável (`trustHosts`)

Problema: o sistema confiava em qualquer proxy e não limitava o `Host`. Um cliente podia escolher o domínio usado nas URLs geradas, inclusive nos links dos e-mails de recuperação de senha (*host header poisoning*).

Solução (`app/Support/HostsConfiaveis.php` , `bootstrap/app.php`): lista **exata** de domínios aceitos: os dois da Vercel do projeto, o `APP_URL`, os endereços de cada deploy (`VERCEL_URL` e similares), `localhost` e os da variável `TRUSTED_HOSTS`. Qualquer outro `Host` ou `X-Forwarded-Host` recebe **400**. Não há curinga `*.vercel.app`, que qualquer pessoa consegue usar com um projeto próprio.

Verificação: como o recurso é desligado em `APP_ENV=local` e nos testes, subi o app em modo produção e testei com cabeçalhos reais: `evil.com` e `evil.vercel.app` receberam 400, e os domínios legítimos 200.

Atenção: um domínio próprio (por exemplo, da escola) **precisa** entrar em `TRUSTED_HOSTS` na Vercel, senão responde 400.

2.4 Bibliotecas de terceiros servidas pelo próprio site

Problema: `qrcodejs`, `jsPDF` e `jsPDF-AutoTable` vinham da cdnjs sem Subresource Integrity. Um comprometimento da CDN executaria código dentro do sistema.

Solução: os três arquivos foram para `public/js/vendor/`, sem alteração. O SHA-512 de cada um é **idêntico ao publicado pela cdnjs** (conferido pela API deles). A CSP deixou de citar qualquer CDN de scripts. O `VendorIntegrityTest` falha se algum arquivo for alterado, e `public/js/vendor/LEIA-ME.md` registra versão, licença (MIT) e hash.

2.5 Rota com a versão do PHP

`GET /dashboard/master/ambiente/php` (só Master, limite de 10 por minuto, `Cache-Control: no-store`) devolve a versão do PHP em execução e se ela já tem a correção das CVEs críticas (`cves_corrigidas`: `true`, `false` ou `null`). Mostra só versões e flags, sem segredos nem caminhos. Arquivos: `app/Support/VersaoPhp.php`, `AmbienteController`. Nasceu da SEC-11, e a revisão automática de segurança motivou o limite de requisições.

---

3. Dependências

Origem	Antes	Depois
`composer audit`	8 avisos em 5 pacotes Symfony	0
`npm audit`	6 avisos (2 críticos, 4 altos), só build/dev	0

- **Symfony:** `http-foundation`, `http-kernel`, `mime`, `routing` e `yaml` foram para a série 7.4.22/7.4.23, com `composer update --with-all-dependencies`. Os avisos incluíam contorno de regras de caminho e de host, e injeção de cabeçalho de e-mail. Esses avisos faziam o módulo 3 do CI falhar.
- **npm:** `npm audit fix`.

---

4. Integração contínua (GitHub Actions)

4.1 Revisão

O pipeline existente tem 6 módulos, PostgreSQL 17 real, sem *secrets* e com `permissions` mínimas. Os problemas e as melhorias estão em `docs/revisao-github-actions.md`.

4.2 O que foi aplicado

Mudança	Arquivo
Atualização automática de dependências (Composer, npm, Actions)	`.github/dependabot.yml`
Revisão de dependências em Pull Requests (alta gravidade, inclusive desenvolvimento)	`.github/workflows/dependency-review.yml`
Varredura de segredos (gitleaks, fixado por SHA, sem publicar o que achar)	`.github/workflows/segredos.yml`
`timeout-minutes: 15` em todos os jobs	`laravel.yml`
Módulo 6 (relatório PDF) corrigido	`laravel.yml`

Revisão de dependências: o job só roda quando a variável do repositório `DEPENDENCY_GRAPH_ATIVO=true` existir, porque a action exige o *Dependency graph* ligado, e só o dono do repositório pode ligá-lo. Sem isso, ele aparece como "pulado".

4.3 Correção do módulo 6 (relatório em PDF)

O módulo já falhava na `main` **antes** deste trabalho: o `apt-get install wkhtmltopdf` dá erro 100 nos runners atuais. Foi trocado por `weasyprint`. Três rodadas da revisão automática de segurança endureceram a geração do PDF, porque o relatório embute texto de origem externa (mensagens de commit, nomes de arquivo, saída do `npm audit`):

1. HTML e LaTeX crus desligados no pandoc (`--from=markdown-raw_html-raw_tex-raw_attribute`).
2. Texto externo em **blocos de código indentados**, em vez de cercas de código que um texto malicioso poderia fechar; `pandoc --sandbox`; checkout do módulo sem guardar o token em `.git/config` (`persist-credentials: false`), que iria parar no PDF publicado.
3. Função `limpa()` que remove caracteres de controle de todo texto externo, inclusive `\r`, que o pandoc trata como quebra de linha e faria o texto sair do bloco.

Cada versão foi validada com execução manual do workflow na branch, já que o módulo 6 só roda fora de Pull Requests.

---

5. Licença

Arquivo `LICENSE` com a **licença MIT**, que o `composer.json` já declarava mas o repositório não trazia. Titular: "Equipe Smart Attendance" (mantido por decisão do grupo). O README ganhou a seção *Licença*.

---

6. Deploy e Vercel

Item	Situação
Deploy de produção nº 1	Após o merge do PR 55 (`7fc1871`); `Ready`
Deploy de produção nº 2	Após o merge do PR 60 (`d2e429a`); `Ready`, alias em `smart-attendance-nine-alpha.vercel.app`
Fork `jooaoleonardi/smart-attendance`	Criado, idêntico ao oficial
Projeto da Vercel ligado ao fork	**Conectado** (a conta da Vercel não enxergava o repositório do Átila: `vercel git connect` falhava)
Deploy automático pelo Git	Ativo na `main` do fork; ainda não testado
Previews de branch	PR 62 os desliga (as variáveis existem só em Production)

Sincronizar o fork com o repositório oficial:

```
gh repo sync jooaoleonardi/smart-attendance
```

---

7. Falhas de segurança

Registro completo em `docs/falhas-de-seguranca.md`.

ID	Falha	Situação
SEC-01	8 avisos de pacotes Symfony	**Resolvida**
SEC-02	Conta Master da demonstração com senha pública (`senha123`)	**Aberta**: trocar a senha em produção (passo a passo no doc)
SEC-03	`trustProxies('*')` sem `trustHosts`	**Resolvida**
SEC-04	Scripts de CDN sem integridade	**Resolvida**
SEC-05	Repasse ao vivo do link do QR a quem está fora da sala	Parcial (foto não vale mais)
SEC-06	6 avisos do `npm audit`	**Resolvida**
SEC-07	Sem autenticação em dois fatores	Aberta
SEC-08	CSP ainda libera `onclick=` e `style=` inline (~58 handlers em 22 views; ~539 atributos `style`)	Parcial
SEC-09	Padrões inseguros no `.env.example`	Aberta
SEC-10	Tempo de sessão com três valores diferentes	Aberta
SEC-11	CVE-2026-109618 e CVE-2026-109619 (execução remota de código no PHP)	**Resolvida em produção**

SEC-11: o PHP de produção

As duas CVEs estão no interpretador PHP (CVSS 9.2). As versões corrigidas são 8.2.35, 8.3.36, 8.4.27 e 8.5.12. O `composer.json` já exigia `^8.2.35`, mas isso não muda o PHP de produção, que vem embutido no runtime `vercel-php@0.9.0`. Investigação:

- O runtime depende de `@libphp/almalinux-9-v85 >=0.0.2`. A versão `0.0.4` desse pacote foi publicada em **21/10/2026**, dia da divulgação, e o binário dela, lido por dentro, é o **PHP 8.5.12**.
- O site publicado responde `X-Powered-By: PHP/8.5.12`.
- Como a dependência é aberta (`>=`), a versão vem do momento do build: vale conferir depois de cada deploy.
- O PHP da máquina de desenvolvimento foi atualizado de 8.5.10 para 8.5.12.

---

8. Testes

	Quantidade
Antes (contagem real na `main`)	209 (o README dizia 204)
Depois	**238** (1.116 verificações)

Testes novos ou reescritos:

Arquivo	Testes	Cobre
`QrRotativoTest`	9	Token, janelas, URL, login com token pendente, endpoint de renovação
`SecurityHeadersTest`	5 (era 1)	CSP sem `unsafe-inline`, nonce diferente a cada requisição, 404 com cabeçalhos
`CspCoberturaTest`	4	Nonce em cerca de 30 telas dos 4 perfis
`VendorIntegrityTest`	3	Hash das bibliotecas, nenhuma view com script de CDN
`HostsConfiaveisTest` (Unit)	3	Lista de hosts aceitos e recusados
`AmbientePhpTest`	6	Versões corrigidas por série, acesso só do Master, limite de requisições

Testes existentes ajustados para enviar o token do QR: `PresencaTest`, `QrCodePresencaTest` e `MasterTurmaTest`.

---

9. Documentação

Novos: `docs/falhas-de-seguranca.md`, `docs/revisao-github-actions.md`, `docs/relatorios/revisao-do-projeto-2026-11.md`, `docs/apresentacao.md` (PR 61) e este relatório. Atualizados: `README.md`, `CHANGELOG.md`, `docs/seguranca.md`, `docs/deploy.md`, `docs/testes-e-ci.md`.

---

10. Pull Requests

PR	Título	Situação
#55	QR Code rotativo, CSP com nonce, licença e revisão do projeto	Mergeado
#56	`trustHosts`, scripts locais, npm, novas actions e CI do relatório PDF	Mergeado
#57	Relatório PDF sem delimitadores controláveis e sem token no disco	Mergeado
#58	Remove caracteres de controle do texto externo no relatório PDF	Mergeado
#59	Registra as CVEs do PHP (SEC-11) e corrige a versão de PHP do CI	Mergeado
#60	Rota do Master com a versão do PHP	Mergeado

PR	Título	Situação
#61	SEC-11 resolvida em produção, senha do Master e roteiro de apresentação	**Aberto**
#62	Desliga deploy automático das branches de trabalho na Vercel	**Aberto**

---

11. Verificações em produção

Feitas sem login, depois do deploy:

- `Content-Security-Policy` com nonce presente em 13 páginas públicas (inclusive o 404), e nenhum `<script>` ou `<style>` em bloco sem nonce;
- os três scripts de `/js/vendor/` respondem 200 com os tamanhos esperados;
- `X-Powered-By: PHP/8.5.12`;
- `/cron/manter-banco-ativo` sem segredo responde 404;
- a rota `/dashboard/master/ambiente/php` sem login responde 401.

Não verificado em produção (exige login): a chamada completa, o QR trocando e o registro de presença pelo celular. Foi verificado **localmente**, no navegador: login do professor, tela da chamada e a troca real do token em 30 s, sem violações de CSP no console.

---

12. Erros e correções durante o trabalho

Registrados por transparência:

- A cópia local em `Documents` estava desatualizada e travava `git` e buscas; o trabalho foi feito num clone novo.
- O README dizia 204 testes, mas o número real era 209.
- Um teste meu do QR (`QrRotativoTest`) falhava em 1 de cada 16 execuções: a adulteração da assinatura usava sempre `0`. Corrigido e repetido 15 vezes sem falha.
- O PR 55 foi mergeado antes dos últimos commits entrarem; o restante foi no PR 56.
- A documentação do CI dizia PHP 8.3, mas ele usa 8.4 (li uma cópia antiga do arquivo). Corrigido.
- O comando `vercel link` acrescentou `.env*` ao `.gitignore`, o que ocultaria o `.env.example`; a alteração foi desfeita.
- O módulo 6 do CI já falhava antes deste trabalho (`wkhtmltopdf`).
- A revisão automática de segurança apontou pontos nos workflows e na rota do PHP; os procedentes foram corrigidos. O pedido de esconder a versão exata do PHP foi recusado, porque ela é o objetivo da rota, que exige login de Master.

---

13. Pendências

Item	Responsável	Observação
Trocar a senha do Master em produção	Equipe	SEC-02; passo a passo em `docs/falhas-de-seguranca.md`
Testar a chamada completa no site publicado	Equipe	QR trocando e presença pelo celular
Mergear os PRs 61 e 62 e sincronizar o fork	Equipe	`gh repo sync jooaoleonardi/smart-attendance`
Domínio próprio em `TRUSTED_HOSTS`	Equipe	Só se o site ganhar domínio próprio
Ligar o Dependency graph e criar `DEPENDENCY_GRAPH_ATIVO=true`	Dono do repositório (Átila)	Só para a revisão de dependências rodar
2FA, migrar `onclick=` / `style=` inline, repasse ao vivo do QR	Evolução futura	SEC-07, SEC-08, SEC-05

14. Como conferir

```
# Testes
php artisan test                          # 238 passando

# Dependências
composer audit                            # sem avisos
npm audit                                 # 0 vulnerabilidades

# Produção
curl -sI https://smart-attendance-nine-alpha.vercel.app/login/professor | grep -iE "content-security|x-powered-by"
```